EXOS AEROSPACE SYSTEMS & TECHNOLOGIES, INC.

SOP-RSKMRSPN

Version 1

Generated August 13, 2026

Confidential — Internal Use Only

Table of Contents

1. Purpose
2. Scope
3. Objectives
4. Roles and Responsibilities
5. Risk Management Process
6. Risk Response Process
7. Risk Categories
8. Risk Management Tools
9. Compliance and Auditing
10. Review and Updates

SOP-RSKMRSPN

1. Purpose

This SOP outlines the procedures for identifying, assessing, mitigating, and responding to risks affecting the organization's systems, operations, and Controlled Unclassified Information (CUI). It ensures compliance with NIST 800-171, DFARS 7012, and CMMC 2.0 Level 2 requirements while maintaining an effective risk management framework.

2. Scope

This SOP applies to:

- All organizational assets, including IT systems, infrastructure, and personnel.
- Risks related to cybersecurity, operational processes, and compliance with regulatory requirements.

3. Objectives

1. Proactively identify and assess potential risks.
2. Implement controls to mitigate identified risks.
3. Maintain operational resilience and protect CUI.
4. Respond to and recover from incidents promptly.
5. Ensure ongoing compliance with applicable regulations.

4. Roles and Responsibilities

1. **Security Admin:**
   - Conducts risk assessments and implements mitigation measures.
   - Oversees the risk management process and ensures implementation of controls.
   - Provides tools and technical guidance for risk management and response.
2. **Company Admin:**
   - Approves risk response strategies and monitors compliance.

5. Risk Management Process

Step 1: Risk Identification

- Sources of Risk:
  - Internal: Process failures, insider threats, system vulnerabilities.
  - External: Cyberattacks, third-party breaches, regulatory changes.
- Potential Methods:

- Use Atomus tools like Microsoft Defender to monitor and identify vulnerabilities in systems.
- Conduct interviews, surveys, and document reviews to identify risks.

Step 2: Risk Assessment

- Evaluate risks based on:
  - **Likelihood:** The probability of occurrence.
  - **Impact:** The potential damage to operations, reputation, or CUI.
- Categorize risks as:
  - High, Medium, or Low.

Step 3: Risk Mitigation

1. Develop and implement controls to reduce risks, such as:
   - Applying system patches.
   - Enforcing access controls and least privilege principles.
   - Deploying encryption for sensitive data.
2. Create and maintain a **Risk Register** that track:
   - Identified risks.
   - Mitigation actions and owners.
   - Status updates.

Step 4: Risk Monitoring

- Regularly review and update the **Risk Register**.
- Monitor systems using automated tools to detect emerging risks.

6. Risk Response Process

Phase 1: Preparation

- Develop a Risk Response Plan covering:
  - Escalation procedures.
  - Communication channels.
  - Incident-specific actions.
- Conduct training on risk response procedures.

Phase 2: Detection

- Use monitoring tools to identify risk indicators or incidents (e.g., anomalous system activity).

Immediately report detected risks to the *Security Admin*.

Phase 3: Containment

- Implement containment measures such as:
  - Isolating affected systems or networks.
  - Disabling compromised user accounts.
  - Blocking malicious IP addresses.

Phase 4: Eradication

- Address the root cause of the risk:
  - Remove malware or unauthorized access.
  - Update policies, configurations, or systems.

Phase 5: Recovery

- Restore normal operations by:
  - Validating system integrity and compliance.
  - Re-enabling affected services with heightened monitoring.

Phase 6: Lessons Learned

- Conduct a post-incident review:
  - Document the risk response process.
  - Identify areas for improvement.

7. Risk Categories

- **Operational Risks:**
  - Disruptions to workflows, including system outages or human error.
- **Compliance Risks:**
  - Violations of regulatory requirements (e.g., DFARS 7012, NIST 800-171, CMMC 2.0 Level 2).
- **Cybersecurity Risks:**
  - Threats from phishing, malware, or ransomware attacks.
- **Third-Party Risks:**
  - Vulnerabilities introduced by vendors or service providers.

8. Risk Management Tools

1. **Risk Assessment Tools:**
   - Microsoft Defender platform for vulnerability scanning and threat identification.
2. **Mitigation Tools:**
   - Endpoint protection, firewalls, and multi-factor authentication (MFA).

3. **Monitoring Tools:**
    - SIEM solutions for real-time monitoring and alerting.

9. Compliance and Auditing

1. **Audits:**
    - Perform quarterly reviews of the Risk Register.
    - Audit implemented controls for effectiveness.
2. **Compliance Monitoring:**
    - Ensure alignment with NIST 800-171, DFARS 7012, and CMMC 2.0 Level 2 standards.

10. Review and Updates

- Review this SOP annually or after significant regulatory changes or incidents.
- Update risk management processes to reflect evolving threats and lessons learned.

This SOP ensures a structured and proactive approach to managing and responding to risks, safeguarding the organization's operations, and protecting sensitive information.

Revision History

Version	Date	Author	Change Summary
v1	Aug 11, 2026	nathaniel@atomus-cyber.com	Initial publication of "SOP-RSKMRSPN".

Acknowledgement & Signature

By signing below, the undersigned acknowledges that the contents of SOP-RSKMRSPN (Version 1) have been reviewed and approved on behalf of Exos Aerospace Systems & Technologies, Inc..

Point of Contact

NAME

Jquinn

TITLE

Chief Executive Officer, Co-Founder

SIGNATURE

DATE

Aug 13, 2026

Signed electronically on Aug 13, 2026